

Incident Management Policy

Policy ID: HH-ISMS-07 **Version:** 1.0 **Effective Date:** 2026-08-29 **Owner:** Venkat Narasimha (Processbricks) **Review Cycle:** Annual **Last Reviewed:** 2026-08-29

Classification: Internal

1. Purpose

When something breaks at a hospital, the cost of confusion is measured in patient hours, salary slips delayed, and shifts missed. This policy exists so that the first 15 minutes of an incident are predictable: severity is clear, the responder knows what to do, the right person is paged, and the close-out produces a post-mortem that prevents recurrence.

Without this policy, 3 AM pages turn into 3 AM heroics; the fix becomes “the person who knew” — institutional knowledge, no audit trail; the same bug returns six months later; silent failures (LEARNINGS #113, #114) become silent outages. With this policy the 15-minute triage is a checklist (../04-runbooks/04.4-incident-response.md), every SEV-1/2 has a post-mortem within 24h (../05-process/05.2-post-mortem.md), every post-mortem writes at least one lesson to .learnings/LEARNINGS.md, and the next incident hits a faster MTTR because the lessons were learned.

The 2026-08-29 prod 500-outage is the canonical case study — a SEV-1 resolved in ~10 minutes because the playbook was followed. This policy formalizes what worked.

2. Scope

2.1 In scope

- **Severity classification** — SEV-1 through SEV-4, with explicit decision rules.
- **Triage flow** — the 15-minute checklist that maps symptoms to hypotheses.
- **Escalation matrix** — when to wake Venkat, when to handle solo, when to stop.
- **Communication templates** — internal status, user-facing, post-resolution.
- **Post-mortem requirement** — SEV-1/2 mandatory, SEV-3/4 optional.
- **Lessons-learned loop** — every incident → at least one LEARNINGS.md entry.
- **Case study library** — the 2026-08-29 500-outage as the canonical example.

2.2 Out of scope

- **Day-to-day operations** — see 05-operations-security.
- **Disaster recovery procedure itself** — see ../04-runbooks/04.3-disaster-recovery.md.
- **Backup and restore details** — see 05-operations-security §3.1 and 08-business-continuity §3.
- **Change management** — see ../05-process/05.1-change-management.md. (Incident-driven changes use the emergency hotfix flow per ../04-runbooks/04.1-deployment.md §“Emergency hotfix”.)
- **Application-level access control** — see 02-access-control.

3. Policy Statement

3.1 Severity classification

SEV	Definition	Examples	Response time	Who acts
SEV-1	Total outage — every request fails; users can't work	HTTP 500 on every page; DB unreachable; nginx 502	wake Venkat IMMEDIATELY	subagent + Venkat
SEV-2	Degraded — some features broken, workaround exists	Roster loads but Attendance fails; one report errors; offsite rsync stale	1 hour	subagent first, Venkat if not resolved
SEV-3	Minor — cosmetic / non-blocking	typo, missing button, slow query, single user affected	1 day	daily queue
SEV-4	Cosmetic — back of queue	alignment, color, copy	when capacity allows	back of queue

Decision rule: if a user CANNOT DO THEIR JOB, it's SEV-1 or SEV-2. If they CAN work but with annoyance, it's SEV-3 or SEV-4.

No silent SEV escalation. A SEV-3 that isn't fixed in 1 day and becomes user-blocking → upgrade to SEV-2. Document the upgrade in the incident log.

No SEV downgrades without justification. If you think it's SEV-3 but Venkat thinks SEV-2, the higher severity wins. Document the disagreement in the post-mortem.

3.2 The 15-minute triage flow

When you suspect an outage (or Venkat reports one), the first 15 minutes follow this fixed order. Full procedure: ../04-runbooks/04.4-incident-response.md §"Triage — first 15 minutes".

1. **Confirm** (2 min) — curl from outside; check / + login endpoint + DB.
2. **Container status** (2 min) — docker ps, RestartCount, resource usage.
3. **Recent changes** (3 min) — git log --since="24 hours ago", backup slots, cron log.
4. **Error logs** (3 min) — docker logs, tabError Log, nginx logs.
5. **Hypothesis** (3 min) — match symptoms to known patterns (table in §3.2).
6. **Decide action** (2 min) — known fix → execute + notify; unknown → notify + investigate together.

Hard rule: if the fix involves DROP TABLE, rm -rf, down -v, or anything irreversible → STOP and notify Venkat BEFORE acting. Per LEARNINGS #72 + the canonical case study.

3.3 Hypothesis → action table

Symptom	Likely cause	Action	Cross-ref
HTTP 500, ModuleNotFoundError in logs	unicorn --preload after bench install-app (LEARNINGS #153)	docker restart erp-{env}-backend-1	§6a Edge 4
HTTP 502, backend logs empty	nginx misconfig	check nginx config + reload	§6a Edge 4
HTTP 503, backend container exited	crash	check logs, restart	../04-runbooks/04.4 §"HTTP 503"

Symptom	Likely cause	Action	Cross-ref
Login returns 401 with right password	DB password drift (LEARNINGS #154)	<code>docker exec erp-prod-db-1 printenv MYSQL_ROOT_PASSWORD</code>	§6a Edge 1
Everything slow, CPU high	runaway query / process	<code>check docker stats + tabError</code> Log for hung queries	../04-runbooks/04.4 §“Slow queries”
Users get “site not found”	DNS issue	check DuckDNS update, ping domain	§6a Edge 8
Backup slot missed	cron failure OR script failure OR disk full (LEARNINGS #79, #80, #113)	per 05-operations-security §6a Edge 1	../04-runbooks/04.4 §“Backup”
Cert expired / renewing failed	duckdns or ACME issue	force-renew, switch to DNS-01 if HTTP-01 blocked	04-cryptography §6a Edge 2
RestartCount > 0 on scheduler	apps.txt ↔ apps/ drift (LEARNINGS #89)	reconcile apps.txt, restart scheduler	05-operations-security §3.7
Silent failure (log looks fine but output is wrong)	<code>bash set -euo pipefail + empty glob</code> (LEARNINGS #113)	audit script for \$(ls *.X) patterns; switch to deterministic paths	05-operations-security §3.1.3
DB connection errors	DB down OR credentials wrong (LEARNINGS #87)	check container + <code>printenv MYSQL_ROOT_PASSWORD</code>	../04-runbooks/04.4 §“DB connection errors”
Slow queries / timeout	hung query OR schema issue	<code>check informatica_schema.processl</code>	../04-runbooks/04.4 §“Slow queries”

3.4 Escalation matrix

Scenario	First action	Notify Venkat	When to stop
Dev env issue	try yourself	NO (no ping)	if blocked > 15 min, ask subagent
QA env issue	try yourself carefully	“QA issue, investigating”	if blocked > 15 min or user-blocking
Prod issue (any SEV)	always notify IMMEDIATELY	YES, Telegram @Miles_Morales_12	never execute <code>DROP/rm -rf/down -v</code> without Venkat
Data loss risk	STOP all changes	YES, “DATA LOSS RISK” prefix	YES never auto-resolve; wait for Venkat
Security incident (suspected breach)	disable the affected account immediately	YES, immediately	YES investigate in parallel; do not delay notification
Backup slot missed	per 05-operations-security §6a Edge 1	depends on slot count missed	if 3+ slots missed → SEV-2
Offsite VPS down	per 01-info-security §6a Edge 5	depends on duration	> 24h → SEV-2 with policy temporarily violated

No silent investigation. If you're investigating for > 10 minutes, post a status update. The 2026-08-29 case study shows this: haritha-diag-500 spawned, root cause in 5 minutes, Venkat updated within 2 minutes.

3.5 Communication

Internal status (Telegram / Slack) The format below is the canonical template. Use it for every SEV-1/2.

SEV-1 first ping:

- PROD SEV-1: {site} returning {symptom}.
- Status:
 - Confirmed via curl from outside ({code}, not {expected})
 - Started ~{time} IST
 - Containers: {status}
 - Last deploy: {commit + 1-line}
 - tabError Log: {spike pattern}
- Hypothesis: {Lesson #X – pattern name}
- Action plan:
 1. {verify}
 2. {fix}
 3. {smoke}
- ETA: {estimate}
- OK to proceed?

During (status update every 5 min if > 10 min):

- {site} SEV-1: {N} min in. {current state}. Executing {next step}.

Resolution / all-clear:

- {site} SEV-1 RESOLVED.
- Summary:
 - Downtime: {HH:MM} ({start} → {end} IST)
 - Users affected: {count or %}
 - Data loss: {NONE / scope}
 - Root cause: {1-line}
- Fix applied: {command}
- Follow-ups:
 - Post-mortem started (LEARNINGS #{number})
 - Runbook updated ({path})

User-facing (if public-facing) Initial (if users start asking):

Subject: [Haritha Hospitals] Brief system interruption - investigating

Team,

We're aware of an issue affecting the ERPNext system. Our team is

investigating and will provide an update within 30 minutes.

If you have urgent work, please save locally and try again later.

Apologies for the inconvenience.

Resolution:

Subject: [Haritha Hospitals] System restored

Team,

The issue has been resolved. The system is fully operational.

Root cause: {1-line, no internal jargon}.

Data: all preserved, no loss.

If you encounter any lingering issues, please report via the usual channel.

3.6 Post-mortem (mandatory for SEV-1/2)

Per ../05-process/05.2-post-mortem.md §“How to use this doc”:

- **SEV-1 and SEV-2: post-mortem within 24h.** Template is in ../05-process/05.2-post-mortem.md §“Part 1”.
- **SEV-3 and SEV-4: optional.** Recommended if the root cause reveals a gap or if the same class of incident could become SEV-1.
- **Lessons-learned entry.** Every SEV-1/2 post-mortem adds at least one numbered entry to .learnings/LEARNINGS.md (prefixed #1XX).
- **Runbook updates.** If the post-mortem reveals a runbook gap, update the runbook in the same 24h window.

The 2026-08-29 500-outage is the canonical example. Lessons #153, #154 (new); #72, #46 (reinforced); runbooks 04.1, 04.4, 05.1, 05.2 updated.

3.7 Lessons-learned loop

1. **Every incident is a lesson.** Document or repeat. No exceptions.
2. **Numbered consistently.** Prefix #1XX for new lessons (continuing the existing series per LEARNINGS.md).
3. **Cite in related documents.** A new lesson updates the Lessons cited footer of any runbook or policy that touches the topic.
4. **Reinforce existing lessons.** If an incident validates a prior lesson, note it as “Reinforced” in the post-mortem (per the 2026-08-29 case study reinforcing LEARNINGS #72).
5. **Anti-pattern: lessons that don’t get applied.** A lesson that no runbook or policy cites is a lesson no one will see. §9 of every policy lists the lesson numbers cited; that list is the assertion that the lesson is applied.

3.8 Single-responder model

- No formal on-call rotation. Single-operator environment.
- **Primary:** Venkat (Telegram @Miles_Morales_12, 24/7 single point of failure).
- **Backup:** ERPClaw subagents (advisory; via sessions_spawn).
- **Vendor support:** Frappe community forum (async, no SLA).
- If Venkat unreachable > 1 hour during SEV-1: execute safest-known fix, document, notify when available.

- If Venkat unreachable > 24 hours: defer non-critical changes; document the deferral in the access register.

3.9 No silent failures (policy)

The single most important incident management rule: **a failure that exits 0 with no useful log line is the highest-severity finding.**

LEARNINGS #113, #114, #153 are the canonical examples:

- **#113:** `set -euo pipefail + $(ls *.tar.gz)` command-substitution trap → silent exit. Backup appeared “running” but produced nothing.
- **#114:** Silent cron failures hide for DAYS if you trust “backup is working”. Always read the actual log file.
- **#153:** Gunicorn `--preload` + new Python package → silent 500 on every request. Direct `python -c "import X"` worked; gunicorn’s frozen `sys.path` did not.

Operational implication: every incident investigation must include a “what would have caught this?” question in the post-mortem. If the answer is “nothing”, that’s a gap to fix in the next iteration.

3a. Current State (as of 2026-08-29)

What we have TODAY

Incident mgmt area	Component	Where it lives	Status
Severity classification	SEV-1 to SEV-4 table	this policy + ../04-runbooks/04.4	Live
Triage flow	15-min 6-step checklist	../04-runbooks/04.4 \$“Triage”	Live
Escalation matrix	dev/QA/prod/data-loss rules	this policy + ../04-runbooks/04.4	Live
Communication templates	internal + user-facing	this policy §3.5	Live
Post-mortem template	part 1 template	../05-process/05.2-post-mortem.md	Live
Post-mortem example	2026-08-29 500-outage filled in	../05-process/05.2-post-mortem.md \$“Part 2”	Live
Case study	2026-08-29 in incident response runbook	../04-runbooks/04.4 \$“Case study”	Live
Lessons-learned loop	numbered #1XX in LEARNINGS.md	../..../.learnings/LEARNINGS.md	Live
Subagent spawn for diagnosis	<code>sessions_spawn(mode=MEMORY, lightContext=true)</code>	MEMORY.md rule #12	Live
Telegram paging	@Miles_Morales_12	Venkat’s phone	Live

What is WORKING

- **The 2026-08-29 500-outage was resolved in ~10 minutes** following the playbook. Diagnosis → hypothesis → volume-verify → restart → all-clear. This is the canonical case for “policy that works in practice, not just in theory”.

- **Post-mortem landed within 4 hours** of resolution (well inside 24h SLA). Lessons #153, #154 written. Runbooks updated same day.
- **Parent-verify pattern (LEARNINGS #72)** saved potential data loss during the 2026-08-29 incident — Venkat asked “will restart clear the data?” and a subagent verified volumes before proceeding.
- **Subagent-driven diagnosis** worked: haritha-diag-500 identified root cause in ~5 min, haritha-verify-volumes confirmed data safety in ~3 min, haritha-restart-both executed the fix.
- **Communication format** (SEV-1 first ping + status every 5 min + all-clear) was followed exactly per the template.
- **Lessons cited in runbooks** — every runbook’s “Lessons cited” footer is updated when a new lesson lands. The 04.4 incident response footer now includes #46, #72, #79, #87, #95, #114, #151-#157.

Known GAPS

1. **No formal incident tracking system.** Incidents live in Telegram chat history + memory/YYYY-MM-DD.md + the post-mortem file. No JIRA-like ticket. Future: lightweight incident table in docs/phase6/incidents/.
2. **No on-call rotation.** Single-operator model. Acknowledged limitation per §3.8.
3. **No automated pager.** Pages are manual (Telegram from a subagent or admin). Future: PagerDuty / OpsGenie integration is out of scope for v1.
4. **No formal SEV-3/4 post-mortem policy.** They’re “optional” per §3.6.2 but the threshold for “is this worth documenting?” is informal.
5. **No chaos engineering.** We don’t proactively inject failures to test the playbook. Future: quarterly game-day with a controlled failure injection.
6. **No runbook auto-generation from post-mortems.** A new lesson must be manually cited in each runbook footer. Future: a script that diffs LEARNINGS.md vs runbook footers and alerts on uncited lessons.
7. **The “user-facing” template assumes users are hospital staff who understand “system”.** For external patients (future patient portal), the tone and detail level would differ. Future revision when patient-facing surface is added.

These gaps are explicit v1 scope decisions. Listing them is transparency, not apology.

3b. Concrete Examples (Haritha history)

Real incidents that shaped this policy. The 2026-08-29 500-outage is the canonical SEV-1 case study; the rest are SEV-2/3 examples that drove refinements.

Example 1 — 2026-08-29 prod 500-outage (LEARNINGS #72, #153, #154) — CANONICAL SEV-1 CASE STUDY

- **What happened.** Both pberpprod and pberpdev returned HTTP 500 on every web request from 03:06 IST to 03:17 IST. 100% of requests failed for ~10 min on both prod and dev. Zero data loss.
- **Root cause.** Unicorn’s --preload flag froze sys.path at container startup. Today’s haritha_hospital install wrote a .pth file invisible to unicorn’s process tree.
- **Response timeline:**
 - 03:06 IST — Venkat reported via Telegram.
 - 03:08 IST — haritha-diag-500 subagent spawned.
 - 03:10 IST — Root cause identified (sys.path frozen + .pth not visible).
 - 03:11 IST — Venkat asked “will restart clear the data?” (LEARNINGS #72 in action).
 - 03:12 IST — haritha-verify-volumes subagent spawned.

- 03:14 IST — Volume verify PASSED (named volumes, no ephemeral layer).
- 03:15 IST — Venkat approved restart.
- 03:16 IST — docker restart erp-dev-backend-1 → dev 200.
- 03:17 IST — docker restart erp-prod-backend-1 → prod 200.
- 03:17 IST — Prod login 401 noted (LEARNINGS #154 secondary failure).
- 03:20 IST — Prod password retrieved from container env, login restored.
- 03:30 IST — Post-mortem started.
- 04:00 IST — LEARNINGS #153, #154 written; runbooks updated.
- **Communication.** SEV-1 first ping template followed exactly. Status updates every 5 min. All-clear sent at 03:17 IST.
- **Post-mortem.** Filed within 4h. Lessons #153, #154 new; #72, #46 reinforced. Runbook updates: 04.1 (added docker restart step), 04.4 (added case study), 05.1 (added LEARNINGS #153 to anti-patterns), 05.2 (template populated).
- **Why this is the canonical case study:** playbook worked end-to-end. Diagnosis in 5 min, fix in 7 min, post-mortem in 4h. No heroics, no shortcuts, no silent failures. This is what the policy exists to enable.

Example 2 — 2026-08-10..18 prod backup silent-failure streak (LEARNINGS #79, #80, #113, #114) — SEV-2 IN RETROSPECT

- **What happened.** prod_backup.sh ran 4x/day from 2026-08-10 through 2026-08-18. Every slot failed silently. Offsite rsync target empty. No error in the cron log.
- **Root cause.** Stale apps.txt hrms reference + set -euo pipefail + \$(ls *.tar.gz) command-substitution trap + missing BACKUP_OK sentinel line. Three stacked issues; all silent.
- **Detection.** 2026-08-18: Venkat discovered the gap during a manual restore drill. **The heartbeat didn't catch it** because the heartbeat was either not running or not probing this metric. This is a SEV-2 in retrospect because offsite backup was broken for 8 days.
- **Response.** Hardened prod_backup.sh with timeout 900, set -euo pipefail, \${PIPES-TATUS[0]} capture, sentinel line. Verified 2026-08-19 with two consecutive cron slots passing.
- **Lessons.** #79, #80, #113, #114. Runbook updates: 04.3 (DR runbook).
- **Why this is in the SEV-2 class:** prod was up, but the offsite backup invariant was violated. If the prod VPS had been lost during this 8-day window, recovery would have been from the last good backup (8 days stale). Per 08-business-continuity §3, the RPO target is 6 hours — an 8-day gap is a 32x RPO violation.
- **Incident management lesson:** the SEV ladder should include “policy invariant violated” as a SEV-2 even when the user-facing service is up. This is now in the §3.1 decision rule.

Example 3 — 2026-08-29 prod DB password drift / 401 incident (LEARNINGS #154) — SEV-1 SUB-INCIDENT

- **What happened.** Within the 2026-08-29 500-outage resolution, prod login returned 401 despite correct password. The password literal in MEMORY.md had drifted from the container env.
- **Root cause.** Hardcoded credential in long-lived markdown doc; rotation in a previous ops session updated the env but not the doc.
- **Response.** Canonical read pattern: docker exec erp-prod-db-1 printenv MYSQL_ROOT_PASSWORD. MEMORY.md gets a permanent CAUTION: literals may be stale banner.
- **Incident management lesson:** the 401 was discovered during the resolution of the 500-outage — i.e., a SECONDARY failure surfaced during a primary fix. The playbook’s “form hypothesis, verify before acting” (LEARNINGS #72) caught it before the admin escalated the 401 to a separate SEV-1. Communication was a single in-thread status update (“prod

login 401 noted; password drift suspected; retrieving from container env”), not a new incident page.

- **Why this matters:** secondary failures during primary fixes are common. The playbook should expect them, not be surprised by them. §3.4 now codifies “secondary failures are part of the primary incident until proven otherwise”.

Example 4 — 2026-08-19 dev-erp scheduler MySQL 1045 silent failure (LEARNINGS #87) — SEV-3 IN RETROSPECT

- **What happened.** erpdev-scheduler-1 runs but every scheduled event silently fails with MySQL 1045 (access denied). Container does not crash; cron is unaffected (uses container env directly).
- **Detection.** Manual review of sites/<site>/logs/scheduler.log (per LEARNINGS #88 — the canonical probe location, not docker logs).
- **Status.** Pending Venkat approval for the MySQL grant fix. Backups unaffected. Open follow-up tracked in 01-info-security §3a.
- **Incident management lesson:** “Container is up” ≠ “Service is functional”. The heartbeat should probe scheduler.log, not just the container. Tracked as a future improvement in 05-operations-security §3.3.1.

Example 5 — 2026-08-21 heartbeat carry-forward drift (LEARNINGS #90) — SEV-3 (NEAR-INCIDENT)

- **What happened.** Daily heartbeat reported Disk: 77% carried forward from Aug 20 06:00 IST for 26 hours. Actual current state: 95% / 4.1G free.
- **Root cause.** Carry-forward across > 6h for drift-prone metrics (disk, memory, container count, apps.txt modtime).
- **Response.** Rule added: fresh probe every ≤ 24h for any drift-prone metric. Disk-prune cron scheduled per LEARNINGS #91.
- **Incident management lesson:** a missed probe is itself an incident. The playbook’s “form hypothesis” step would have asked “is the probe still valid?” if the operator had been checking. Carry-forward without verification is the same class of silent failure as LEARNINGS #113/114.

Example 6 — 2026-08-21 disk near-full (LEARNINGS #91) — SEV-2 (PREVENTED)

- **What happened.** Main VPS disk reached 95% on a 72G root. 13.4G reclaimable from dangling Docker images.
- **Detection.** Fresh disk probe (post-LEARNINGS #90 rule).
- **Response.** Scheduled weekly Sunday 04:00 IST docker image prune -a cron. Did not wait for 100% full.
- **Incident management lesson:** this was a prevented incident, not a real one. The lesson is “the heartbeat should probe, not just report”. Tracked in 05-operations-security §3.3.

Example 7 — 2026-08-14 sub-agent verification gap (LEARNINGS #72) — PROCESS-LEVEL SEV-3

- **What happened.** Two sub-agent “done” reports had silent discrepancies caught only by parent verification (nginx worker count, git pull state). The work was technically complete but functionally wrong.
- **Root cause.** Sub-agent verified “the script parses” but not “the script behaves”. Behavior assertions were missing.

- **Response.** Parent-verify checklist added: worker/process counts via ps/ss; git state via git rev-parse; file content via sha256sum/stat; service health via direct REST call.
- **Incident management lesson:** sub-agent completion claims are not evidence. The operator (or a verifier sub-agent) must re-probe. This is now in §3.4 escalation — “verify, then escalate”.

Example 8 — 2026-08-11 Roster delete-after-submit (LEARNINGS phase6/04 Wave 5) — SEV-3

- **What happened.** A test Roster entry was deleted immediately after submit (Frappe framework default for some HRMS docs). Wave-5 verification had no record of the entry existing post-submit, so the test looked like a flake.
- **Root cause.** Frappe framework default for some HRMS docs is delete_after_submit = 1. Custom apps inherit the default unless overridden.
- **Response.** Wave-5 script updated to query tabVersion (audit log) to detect soft-deletes. Chart-config test fixtures use named, persisted sample data.
- **Incident management lesson:** audit logs are an incident-management primitive — they answer “what did this doc look like yesterday?”. Without tabVersion populated, future investigations can’t see what happened. Cross-link to 02-access-control §3.4 Life-cycle.

Example 9 — 2026-08-22 SSH key chmod issue (LEARNINGS #93) — SEV-3

- **What happened.** /root/.openclaw/*.key files lost 0600 mode. SSH refused to use them.
- **Root cause.** Filesystem mode is host-level state that drifts.
- **Response.** Periodic chmod 0600 in bootstrap script.
- **Incident management lesson:** state drift (file mode, key ownership) is an incident-management concern, not just a hygiene concern. The “verify before acting” principle (LEARNINGS #72) extends to “verify state before assuming”.

4. Responsibilities

Role	Responsibilities
Venkat Narasimha (Owner)	Approves this policy + exceptions. Approves all prod emergency actions. Receives SEV-1/2 pages. Reviews all post-mortems within 24h. Owns the lessons-learned loop.
Processbricks admin	First responder on SEV-3. Escalates SEV-1/2 immediately. Files post-mortems within 24h. Updates runbooks after post-mortem close-out. Reviews LEARNINGS.md monthly for new lessons.
Subagents (automation)	Run heartbeat probes on schedule. Spawn diagnostic subagents when heartbeat fails. Surface unknowns to operator within 5 min. Never auto-execute destructive ops on prod without Venkat approval.
All users	Report anomalies within 1h (per 01-info-security §3). Don’t share credentials. Don’t bypass MFA. Don’t run ops commands against prod without authorization.

Role	Responsibilities
Vendors	Bound by contract to provide CVE notification within 7 days. Bound by §3.5 user-facing communication templates when issuing public advisories that affect Haritha users.

5. Compliance Measurement

Check	Frequency	Owner	Source of truth
All SEV-1/2 incidents have a post-mortem within 24h	Per incident	admin	docs/phase6/post-mortems/
All SEV-1/2 post-mortems add at least 1 LEARNINGS.md entry	Per incident	admin	diff of LEARNINGS.md
All new LEARNINGS.md entries are cited in relevant runbooks within 7d	Per lesson	admin	runbook footers
Heartbeat probe actually ran (not carried forward)	Daily	subagent	heartbeat log
SEV classification was correct (no downgrades without justification)	Per incident	Venkat	post-mortem “SEV justification” section
Communication templates followed	Per SEV-1/2	admin	Telegram log + post-mortem git log
Runbook updates landed within 24h of post-mortem	Per incident	admin	
Lessons-cited footer accuracy	Quarterly	admin	grep runbook footers vs LEARNINGS.md
Quarterly review of incident patterns (e.g., “are we seeing the same class of failure?”)	Quarterly	Venkat	aggregate post-mortem table
Annual tabletop exercise for DR	Annually	Venkat	tabletop notes

KPI dashboard (informal):

KPI	Target	Source
Mean Time to Detect (MTTD) for SEV-1/2	≤ 5 min	heartbeat / user report

KPI	Target	Source
Mean Time to Resolve (MTTR) for SEV-1	≤ 30 min	post-mortem timeline
Mean Time to Resolve (MTTR) for SEV-2	≤ 4 hours	post-mortem timeline
Post-mortem within 24h SLA	100%	post-mortem file mtime
Lesson-citation lag (lesson → runbook update)	≤ 7 days	git log
Same-class incident recurrence	0 (per LEARNINGS.md entry)	aggregate review

6. Exceptions

1. **No formal on-call rotation** (§3.8). Tracked — single-operator model for v1.
2. **No automated pager** (§3a GAPS #3). Telegram-based manual paging is the compensating control.
3. **SEV-3/4 post-mortems are optional** (§3.6.2). Threshold is informal; documented per incident in the post-mortem file.
4. **All other exceptions** follow 01-info-security §6.

6a. Edge Cases & Decision Matrix

Specific scenarios that test the policy's boundaries. Each entry includes the trigger, the decision, and the rationale.

Edge case 1 — A SEV-1 happens during off-hours and Venkat is unreachable

- **Trigger.** 03:00 IST. Prod is down. Telegram ping sent. No response within 15 min.
- **Decision matrix.**

Action	Allowed?	Why
Continue triage without Venkat	YES (for diagnosis only)	Diagnosis is read-only
Execute the safest known fix without Venkat	CONDITIONAL	Only if the fix is docker restart or similar reversible action; document the action
Execute any irreversible fix	NO	LEARNINGS #72 + §3.2 Hard rule
Wait indefinitely for Venkat	NO	§3.8 — 1-hour cap on waiting
Page a subagent to escalate further	YES (advisory only)	Subagents are not authoritative for prod

- **Default action.** Continue triage. Execute docker restart if hypothesis is clear and it's the safest known fix. Document everything. All-clear Telegram message sent when Venkat responds. Post-mortem includes the unreachable-Venkat window as a process gap.

Edge case 2 — Two SEV-2 incidents happen simultaneously

- **Trigger.** Roster is slow AND offsite rsync is failing AND a user reports a missing button.
- **Decision matrix.**

Action	Allowed?	Why
Spawn one diagnostic subagent per incident in parallel	YES	Parallel-subagents pattern (MEMORY rule #12)
Pick the highest-impact to triage first	NO	All three are SEV-2; don't triage by gut
Declare all three a single SEV-1	NO	They're independent; lumping them loses signal
Post a status message naming all three	YES	Transparency; operator can prioritize

- **Default action.** Parallel subagents. Each writes to its own incident log. Post-mortem is one file with three sections.

Edge case 3 — A SEV-1 is caused by a known anti-pattern from a prior post-mortem

- **Trigger.** The same class of failure recurs within 90 days of a post-mortem.
- **Decision matrix.**

Action	Allowed?	Why
Treat as SEV-1 (don't downgrade)	YES	Recurrence is itself an SEV-1 signal; the prior mitigation didn't work
Re-run the prior post-mortem template	NO	Use a fresh template; cite the prior PM in the "Related" section
Add a follow-up entry to the prior LEARNINGS.md line	YES	"Reinforced, recurrence" annotation
Escalate to "policy violation" classification	YES	If the same lesson is cited in the runbook but the operator missed it, the policy is being bypassed

- **Default action.** Fresh post-mortem with prior PM cited. Lesson gets a "Reinforced" annotation. Quarterly review asks "is this lesson-citation pattern working?"

Edge case 4 — The fix for a SEV-1 reveals a deeper bug

- **Trigger.** Roster is down (SEV-1). Restart fixes it. But during the restart, a tabError Log query reveals a long-running schema bug that was the actual root cause.
- **Decision matrix.**

Action	Allowed?	Why
Restart first, investigate the deeper bug as a separate incident	YES	Don't let the SEV-1 fix scope creep
Treat both as one SEV-1	NO	Different fixes, different timelines
File the deeper bug as a SEV-3	YES (after triage)	It's user-impacting but not user-blocking; classify by impact

- **Default action.** Restart resolves the SEV-1. Deeper bug is a new incident — file a fresh post-mortem or add to the existing one with a separate “Secondary finding” section. Don’t conflate.

Edge case 5 — A user reports a problem that turns out to be user-side (not a system issue)

- **Trigger.** Nurse reports “Roster is broken”. Investigation shows it’s her browser cache or VPN.
- **Decision matrix.**

Action	Allowed?	Why
Treat as a SEV-3 (still user-facing impact)	YES	Even user-side, the user experience was broken
Write a post-mortem	NO	SEV-3 is optional per §3.6.2; this case has a clear “not our fault” root cause
Document the workaround in a FAQ	YES	Future users may hit the same issue
Skip documentation entirely	NO	Future investigators will rediscover the same false-positive

- **Default action.** Help the user with the workaround (cache clear, VPN check). Document the false-positive pattern in the heartbeat log. No post-mortem; the FAQ entry is enough.

Edge case 6 — The on-call admin is the one who caused the incident (e.g., a bad deploy)

- **Trigger.** PA deployed a hotfix to prod; the hotfix caused SEV-2. PA is the first responder.
- **Decision matrix.**

Action	Allowed?	Why
PA continues to triage and rollback	YES	PA has the most context; hand-off adds latency
PA must explicitly document “I caused this” in the post-mortem	YES	Honesty > blame; the post-mortem is blameless per ../05-process/05.2-post-mortem.md
Page Venkat for rollback approval	YES (mandatory)	Cross-check by another operator is required for prod rollback
Skip Venkat approval because “I know what I did”	NO	§3.2 Hard rule — irreversible fixes need explicit YES

- **Default action.** PA triages. Venkat approves rollback. Post-mortem uses blameless language (“the hotfix introduced a regression” not “PA broke prod”).

Edge case 7 — An incident is in flight when the heartbeat subagent fails

- **Trigger.** Mid-incident at 03:30 IST. The 03:00 IST heartbeat probe didn’t run (subagent session limit). Incident response continues manually.

- **Decision matrix.**

Action	Allowed?	Why
Continue incident response manually	YES	Heartbeat is observational, not on the critical path of the fix
Spawn a fresh heartbeat subagent mid-incident	YES (low priority)	Won't disrupt the response; useful for "what else is broken?" checks
Skip heartbeat for the rest of the incident	NO	LEARNINGS #90 — carry-forward is dangerous
Document the heartbeat gap in the post-mortem	YES	It's a contributing factor if anything else is missed

- **Default action.** Continue manual response. Document the gap. Future improvement: cron-based heartbeat shell script as authoritative fallback (05-operations-security §3a GAPS #5).

Edge case 8 — A post-mortem reveals a security incident (not just an outage)

- **Trigger.** During the 2026-08-29 incident, investigation reveals unauthorized SSH login attempts in `/var/log/auth.log` from a foreign IP.
- **Decision matrix.**

Action	Allowed?	Why
Treat as SEV-1 (security > outage for triage)	YES	Security incidents escalate immediately per 01-info-security §6a Edge 7
Disable the affected tabUser (if any) first	YES	Disable first, investigate second per the §6a rule
Combine the security + outage post-mortems	NO	Different audiences, different escalation paths
File both as separate post-mortems with cross-references	YES	Each gets its own PM; "Related" sections point to each other

- **Default action.** Security triage first (disable accounts, revoke tokens, audit access). Outage triage second (existing playbook). Two post-mortems, cross-referenced.

7. Related Documents

- 01-info-security.md — Umbrella + emergency-access + exception flow.
- 02-access-control.md — Account compromise → disable within 1h.
- 03-asset-management.md — Classification drives what counts as a security incident.
- 04-cryptography.md — TLS / SSH compromise response.
- 05-operations-security.md — Heartbeat integration + change management during incidents.
- 06-communications-security.md — Network/TLS-related incidents (sibling policy).
- 08-business-continuity.md — DR + RTO/RPO when incidents escalate to DR (sibling policy).
- ../04-runbooks/04.4-incident-response.md — Full triage flow + communication templates + case study.

- ../04-runbooks/04.3-disaster-recovery.md — DR procedure for total-loss incidents.
- ../05-process/05.1-change-management.md — Emergency hotfix flow for SEV-1/2.
- ../05-process/05.2-post-mortem.md — Post-mortem template + 2026-08-29 example.
- ../../../../learnings/LEARNINGS.md — All lessons; this policy’s lessons-cited footer lists the most relevant.
- ../../../../MEMORY.md — Tech stack + subagent orchestration patterns.

8. Revision History

Version	Date	Author	Changes
1.0	2026-08-29	venkat-narasimha	Initial

9. Implementation Checklist

Concrete actions derived from this policy. Owner initials: VN = Venkat Narasimha; PA = Processbricks admin. Status as of 2026-08-29.

Immediate (this week)

- ☐ **Create docs/phase6/post-mortems/ directory** (per ../05-process/05.2-post-mortem.md §“Part 1”). Owner: PA. Target: 2026-09-05. Status: Not Started.
- ☐ **File the 2026-08-29 500-outage post-mortem** in the new directory (currently inline in ../05-process/05.2-post-mortem.md §“Part 2”; future PMs go to dedicated files). Owner: PA. Target: 2026-09-05. Status: Not Started.
- ☐ **Audit all runbook Lessons cited footers** vs the latest LEARNINGS.md entries. Flag any uncited lessons within 7 days of publication. Owner: PA. Target: 2026-09-05. Status: Not Started.

Short-term (2026-Q3)

- ☐ **Author a lightweight incident table** at docs/phase6/incidents/index.md (date, env, SEV, root cause, PM link, lesson numbers). Owner: PA. Target: 2026-09-30. Status: Not Started.
- ☐ **Add a “secondary failure” section** to the post-mortem template (per §3b Example 3). Owner: VN. Target: 2026-09-30. Status: Not Started.
- ☐ **Define a SEV-3/4 documentation threshold** (e.g., “any SEV-3 with > 1 user affected OR any root cause revealing a gap”). Owner: VN. Target: 2026-09-30. Status: Not Started.
- ☐ **Quarterly incident pattern review** (script that aggregates post-mortems by root-cause class). Owner: PA. Target: 2026-09-30. Status: Not Started.
- ☐ **Add a Telegram bot hook** for SEV-1/2 pings (so the page doesn’t depend on a subagent being available). Owner: PA. Target: 2026-10-15. Status: Not Started.

Medium-term (2026-Q4)

- ☐ **Quarterly game-day / chaos engineering** (controlled failure injection). Owner: VN. Target: 2026-12-15. Status: Not Started.
- ☐ **Runbook auto-citation script** (diff LEARNINGS.md vs runbook footers; alert on uncited lessons). Owner: PA. Target: 2026-11-15. Status: Not Started.
- ☐ **Tabletop exercise for DR** (annual; cross-link 08-business-continuity §9). Owner: VN. Target: 2026-12-15. Status: Not Started.
- ☐ **First formal SEV-3/4 post-mortem** filed (proves the threshold in practice). Owner: PA. Target: 2026-10-31. Status: Not Started.

Long-term (2027+)

- ☐ **PagerDuty / OpsGenie integration** for automated paging. Owner: VN. Target: TBD. Status: Not Started.
- ☐ **Second operator onboarding** (breaks the single-responder model; see §3.8). Owner: VN. Target: TBD. Status: Not Started.
- ☐ **Postmortem analytics dashboard** (MTTR by SEV, recurrence rate, lesson-citation lag). Owner: VN. Target: TBD. Status: Not Started.

Recurring verification (runs forever)

- ☐ **Heartbeat probe** (subagent at 08:30 IST; per 05-operations-security §3.3). Owner: PA. Frequency: daily. Status: Done.
- ☐ **Heartbeat freshness assertion** (probe ran within last 26h; per LEARNINGS #90). Owner: PA. Frequency: daily. Status: Done.
- ☐ **Post-mortem within 24h SLA** for every SEV-1/2. Owner: PA. Frequency: per incident. Status: Done.
- ☐ **Runbook update within 24h** of post-mortem close-out (when a gap is revealed). Owner: PA. Frequency: per incident. Status: Done.
- ☐ **LEARNINGS.md monthly review** (new lessons, citation gaps). Owner: PA. Frequency: monthly. Status: Done.
- ☐ **Quarterly incident pattern review** (aggregate post-mortems). Owner: VN. Frequency: quarterly. Status: Not Started.
- ☐ **Annual policy review** (re-read, increment version). Owner: VN. Frequency: annually. Status: Done (this revision).

Document or repeat. Verify before acting. Parent-verify before claiming SUCCESS. No silent failures.